TITAI

v15 - Sovereign Intelligence, Local-First Infrastructure, and Breakthrough Implementation

ENGINEERING REPORT

SOVEREIGN DEVELOPMENT MODE

STANDARD RELEASE: DEVELOPMENT ONLY

Field	Value
Engineering date	11 July 2026
Input release	TITAI v14 validation
Input SHA-256	d725fa1dbc2ab026bbb03affda3b8ddd086195e8a9ff22e1a2c9c64a302cbb64
Scope	Zero-key core, air-gap handoff, offline update, local trust, memory portability, hardware/energy placement, sovereignty control plane
Evidence policy	Unknown mandatory evidence is blocking evidence

Controlled independence - useful, recoverable and understandable without mandatory commercial infrastructure.

Document map

- Executive decision
- Verified starting state
- Sovereignty vector and architecture
- Mandatory vertical slices
- Security and trust
- Data, memory, hardware and energy
- Dependency and network posture
- Testing and release evidence
- Roast findings
- Classifications and next cycle
- Appendix - Complete finding register

1. Executive decision

v15 proves three mandatory sovereign vertical slices: a zero-key local workflow, a signed air-gap handoff, and a signed offline update with rollback. The core workflow requires no commercial API key, hosted identity, remote database, remote memory or mandatory external runtime service.

The cycle also closes an adversarial gap discovered during implementation: signature integrity alone did not prevent replay or allow local revocation. Task and result acceptance now requires a purpose-scoped, tenant-scoped, workspace-scoped, valid and non-revoked trust key, then consumes a durable replay identifier that survives restart.

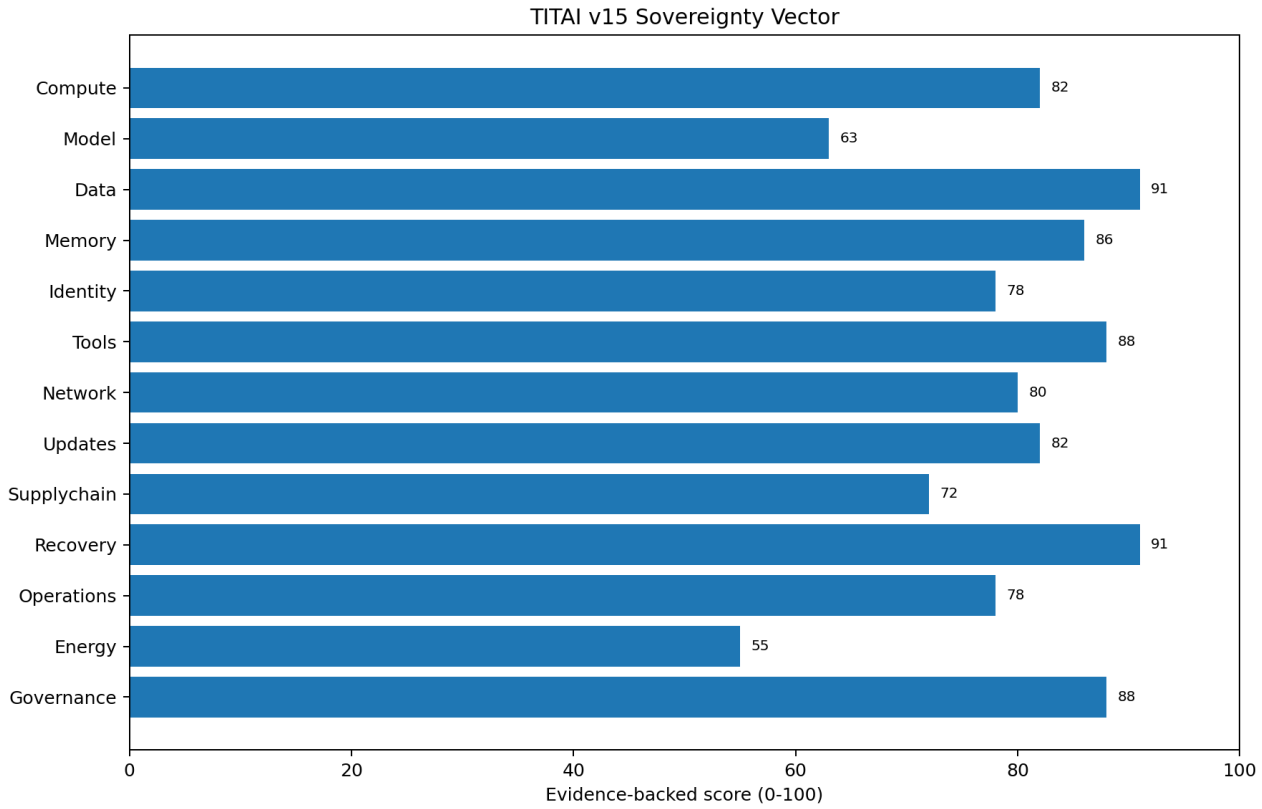
The accurate classifications remain SOVEREIGN DEVELOPMENT MODE and DEVELOPMENT ONLY. No real generative local model has been benchmarked; complete process-level outbound observation, measured target-hardware energy, disconnected clean installation, automatic migration rehearsal and external independent verification remain incomplete.

Outcome	Result
Mandatory sovereign vertical slices	3 / 3 passed
Regression	59 files; 180 / 180 tests passed
Sovereignty-focused tests	10 files; 21 / 21 tests passed
Production build	Passed; 92 seconds; 2 workers
Roast	76 findings; static 43/44; dynamic 6/6 functional
Classification	SOVEREIGN DEVELOPMENT MODE + DEVELOPMENT ONLY

2. Verified starting state

- v14 archive hash reproduced exactly.
- Canonical, language, lint, migration, TypeScript, release audit, evaluation, crash proof and production build gates rerun.
- All prior SQLite persistence suites remain executable through the Node built-in SQLite compatibility lane.
- The complete regression is proved through deterministic split execution because the monolithic Vitest process retains an open handle after reporting every suite.
- No antivirus, firewall or managed browser policy was weakened. No model weights or generated native binaries are packaged.

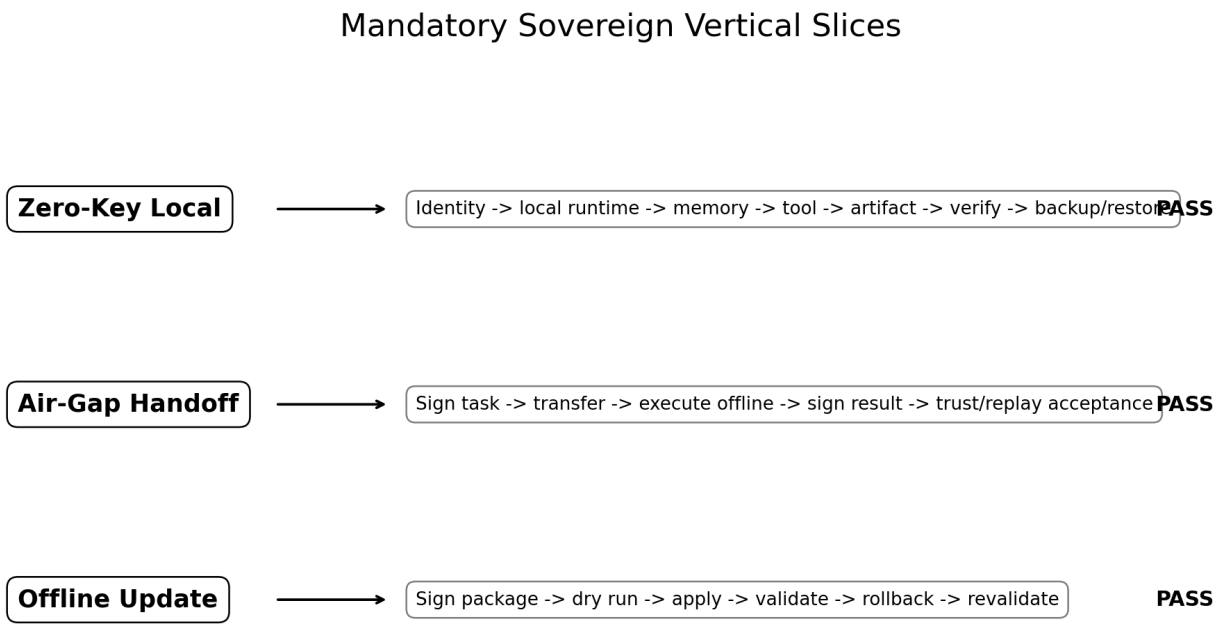
3. Sovereignty vector and architecture



The vector is evidence-backed and deliberately uneven. High data and recovery scores do not conceal weak model and energy evidence. Fatal weaknesses and mandatory external dependencies are evaluated before any aggregate interpretation.

Dimension	Score	Evidence interpretation
Compute	82	Local persistence and execution available
Model	63	Runtime abstraction; real model quality unproven
Data	91	Authoritative local storage and export
Memory	86	Portable governed local memory
Identity	78	Local identities, purpose and revocation
Tools	88	Local capability-controlled tool pack
Network	80	Guarded adapters; full observation missing
Updates	82	Signed apply and rollback
Supplychain	72	Manifest/SBOM; clean bundle missing
Recovery	91	Encrypted backup and clean restore
Operations	78	Control plane and fail-closed evidence
Energy	55	Policies and estimates; no measurements
Governance	88	Tasks, claims, ADRs and verification

4. Mandatory sovereign vertical slices



4.1 Zero-key local workflow

Local identity -> local runtime eligibility -> governed memory -> local tool -> artifact -> local evidence -> separate verifier identity -> encrypted local backup -> clean restore.

Evidence	Value
Selected runtime	deterministic-local-v1
Artifact SHA-256	c94002c08ec7b70669d5ecad75e2d949a7d00c4ecf143293b12080933dd62f21
Workflow evidence SHA-256	2a8d5a20e50f42bc3ddf5cd0fb67390a84aad0e4bb6a08c25e88c6eefc634fb7
Network attempts	0
Result	PASS

The deterministic local runtime proves the architecture and safety contracts. It does not prove useful generative reasoning quality.

4.2 Signed air-gap handoff

The signed task binds identity, tenant, workspace, receiver, objective, context, memory hashes, evidence references, capability limits, expiry and return schema. The separately signed result binds the exact task payload hash and cannot exceed the capability grant.

Control	Evidence
Task payload hash	2f27e5fb8b3ee3846c56ce0d16a0f92af476af775e802054f673cbba6249c4f7
Result payload hash	7ee0f1136fcbb0738bfd9a8d9650fd801fd810c59694f33f71e1e8f710b28215
Durable replay rejection	TRUE
Trust store enforced	TRUE
Result	PASS

4.3 Signed offline update

The update binds source and target versions, file bytes and modes, deletion paths, compatibility, declared migrations, validation commands and release-evidence hashes. Apply uses a rollback copy and restores the previous installation after an injected failure.

Evidence	Value
Update payload hash	8159112a4d401196c1f572004525353b2b5293cbc5d06cf2ca491a18527d976a
Applied version	1.15.0
Rolled-back version	1.14.0
File apply/rollback	PASS
Automatic DB migration rehearsal	NOT YET PROVEN

5. Security, identity and key custody

- HKDF purpose/context separation prevents one undifferentiated application key from serving every use.
- Ed25519 signing is separated from encryption and backup key material.
- The local trust store checks key purpose, tenant, workspace, validity period and revocation.
- The durable replay ledger rejects consumed tasks and results after restart and treats identifier reuse with altered payload as a collision.
- Private signing keys and root recovery keys are excluded from evidence bundles.

Remaining limitation: software-protected PEM and in-memory roots are not equivalent to TPM, OS-keychain, hardware-token or formal recovery-custody procedures.

6. Data and governed memory

The local store remains authoritative. Portable memory records preserve content hash, type, provenance, authority, confidence, scope, sensitivity, expiry, corrections and contradiction metadata. Import verifies integrity, tenant/workspace scope, duplicates and conflicts. Confidence decay reduces stale procedural authority.

Memory control	v15 state
Canonical local authority	Implemented
Open export/import	Implemented
Duplicate/conflict detection	Implemented
Confidence decay	Implemented
Derived vector-index rebuild	Designed; real embedding adapter absent
Remote memory authority	Not permitted in sovereign core

7. Hardware, node placement and energy

Property	Reference evidence
Reference node	local-mini-pc
RAM	16 GiB
Maximum power profile	65 W
Network availability	False
Selected placement	local-mini-pc
Energy confidence	Estimated, not measured

Hard constraints are evaluated before utility. A model or node that lacks RAM, CPU compatibility, tenant authority, required privacy, offline capability or energy headroom is ineligible regardless of quality score.

8. Dependency and network posture

Metric	Value
Dependency records	526
Local-authoritative	524
Remote-optional	2
Mandatory external runtime in declared core	0
Recorded controlled network attempts	1
Full process-level network audit	BLOCKED / NOT PROVEN

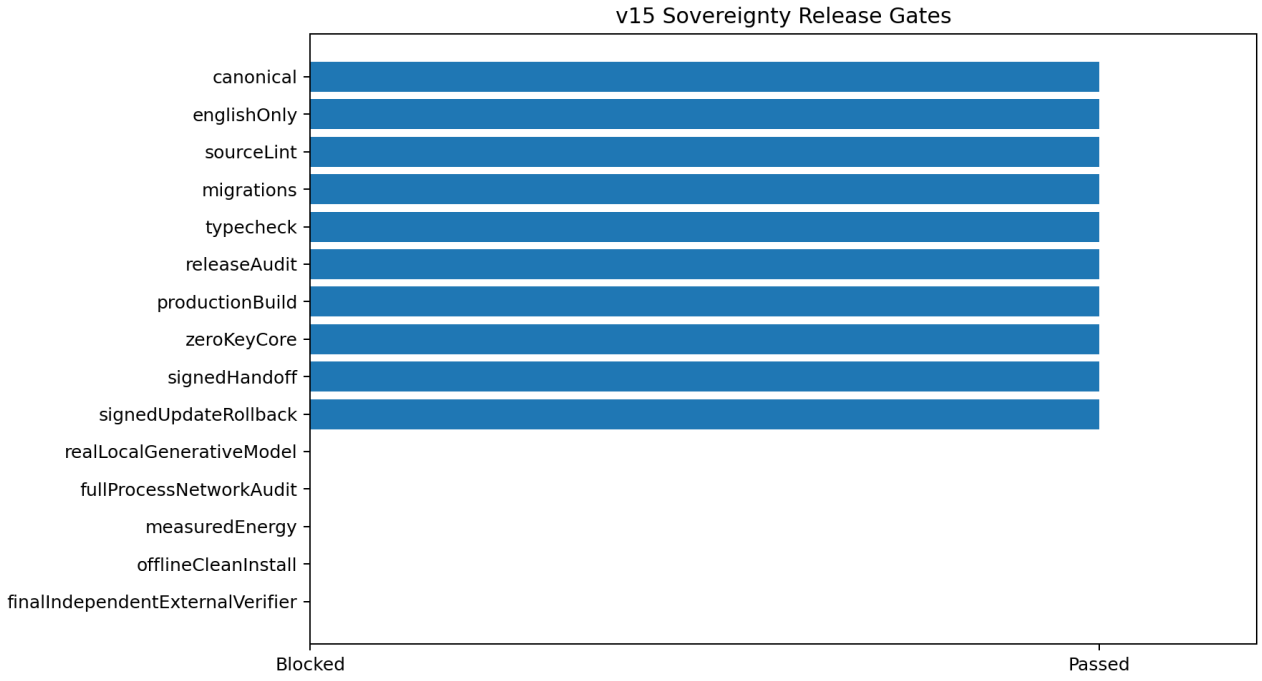
The application-level guard denies external requests in air-gap mode. The current container does not permit network namespaces or syscall tracing, so a complete observation of startup, build, execution and shutdown remains a release blocker.

9. Opportunity portfolio and breakthrough lab

The repository contains 30 ranked sovereign opportunities and 15 falsifiable breakthrough hypotheses. Selection intentionally combines an immediate low-risk improvement, a medium-complexity platform capability and a difficult disconnected-execution experiment.

Selected implementation	Why it matters
Zero-key local workflow	Removes mandatory commercial credentials and hosted runtime for the core path.
Signed handoff + trust/replay	Moves bounded work across an air gap without expanding authority or accepting replay.
Signed offline update	Allows controlled evolution without a live update service and preserves rollback.
Hardware-aware placement	Prevents impossible or unauthorized nodes/models from winning utility scoring.
Sovereignty Control Plane	Makes locality, dependencies, network, recovery and blockers operator-visible.

10. Testing, build and release evidence



Gate	Result
Canonical	PASS - 88 tasks, 95 claims, 38 ADRs

Gate	Result
English-only	PASS
Source lint	PASS
Migrations	PASS
TypeScript	PASS
Regression	PASS - 59 files, 180 tests
Sovereignty focused	PASS - 10 files, 21 tests
Baseline evaluation	PASS - 8/8
Durable crash proof	PASS - exactly one side effect
Mutation probes	PASS - 12/12 killed
Dynamic Roast	6/6 functional; process-exit issue recorded
Static Roast	43/44
Production build	PASS - 92 seconds, 2 workers
Release audit	PASS

The build produces a 103 kB shared first-load bundle and a 103 kB sovereignty page first-load path. No SQLite connection is opened during module discovery.

11. Roast summary

Severity	Count
Critical	13
High	50
Medium	13
Status	**Count**
accepted_risk	1
environment_blocked	4
fixed_in_v10	6
fixed_in_v11	3
fixed_in_v12	5
fixed_in_v13	2
fixed_in_v14	4
fixed_in_v15	1
fixed_in_v8	13
open	6
partially_mitigated	31

11.1 New v15 findings

F-069 - Full-process outbound network behavior is not independently audited

HIGH / open: An undeclared dependency or library call could escape the application-level guard and invalidate air-gap claims. Required action: Run the extracted release in an isolated network namespace with deny-by-default egress and capture all connection attempts.

F-070 - No real local generative model artifact has been benchmarked

CRITICAL / open: Model sovereignty, task quality, tool reliability, memory behavior, latency, and hardware feasibility remain unproven for a useful generative workload. Required action: Benchmark at least one license-reviewed local model artifact in a disposable environment and bind its hash, runtime, quality, memory, latency, and energy evidence to the registry.

F-071 - Energy-aware scheduling uses estimates rather than measured hardware data

HIGH / open: Energy-saving, thermal-protection, and local-versus-remote break-even decisions may be materially wrong on target hardware. Required action: Collect repeated wall-power or trusted telemetry measurements for idle, model load, inference, retrieval, backup, and restore.

F-072 - Clean offline installation still depends on an unbuilt dependency bundle

HIGH / open: Loss of public registries or model hubs prevents clean installation and disaster recovery onto replacement hardware. Required action: Create a license-compliant signed installation bundle with package, system, browser, and model manifests plus integrity verification.

F-073 - Signed air-gap bundles were replayable and ignored local key revocation

HIGH / fixed_in_v15: An attacker or operator error could repeat bounded work, duplicate local writes, or accept evidence from a revoked offline node. Required action: Retain purpose-scoped trust checks and a durable replay ledger at the acceptance boundary.

F-074 - Offline update migration execution is declared but not automatically rehearsed

HIGH / partially_mitigated: A source update may apply successfully while its schema change fails or cannot be rolled back. Required action: Add a staged database-copy rehearsal, migration ledger verification, application validation, and explicit schema rollback policy before committing the update.

F-075 - Root and signing keys lack protected hardware custody and rotation proof

MEDIUM / partially_mitigated: Host compromise could expose all software-protected sovereign identities and backup keys. Required action: Implement optional OS keychain or TPM-backed adapters, rotation ceremonies, recovery-key separation, and secret-access audit.

F-076 - Monolithic test orchestration retains an open handle after all suites report

MEDIUM / partially_mitigated: CI can hang after successful tests, wasting capacity and obscuring real timeouts. Required action: Identify the leaked timer, database handle, worker, or server and add an open-handle regression gate.

12. Classifications and release decision

Classification system	Decision	Reason
Sovereignty	SOVEREIGN DEVELOPMENT MODE	Three vertical slices pass; real model, full network audit, measured energy and offline clean install remain incomplete.
Standard release	DEVELOPMENT ONLY	No browser-independent external verifier or sovereign pilot proof on target hardware.

12.1 Required v16 convergence

1. Benchmark one license-reviewed real local model on the user mini-PC or isolated equivalent.
2. Build and test a signed disconnected installation bundle for packages, system requirements, browser artifacts and the chosen model.
3. Run the final extracted application in a deny-by-default network environment and capture every outbound attempt.
4. Rehearse a real database migration within the signed update, validate, rollback and revalidate.
5. Move root/signing keys into an optional protected custody adapter and execute an external hash-bound verification.

Appendix A - Complete finding register

All historical findings are retained. Compact presentation does not change acceptance criteria or evidence references.

ID	Severity	Status	Title	Impact / correction / acceptance
F-001	critical	partially_mitigated	Detached in-memory execution cannot survive process loss	Impact: Long-running or side-effecting jobs can disappear, duplicate, or remain permanently inconsistent after deployment, crash, or upgrade. Correction: Complete native multi-process crash tests and replace the single-step envelope with granular checkpoints and fencing. Acceptance: Kill the worker at every checkpoint boundary and prove the run resumes exactly once with preserved ownership and evidence.
F-002	critical	partially_mitigated	Side effects lack persisted idempotency and atomic evidence	Impact: A crash after a side effect but before acknowledgement can repeat irreversible work or create evidence that disagrees with reality. Correction: Migrate the production runner to the portable contract with a SQLite compare-and-set lease and transactional outbox. Acceptance: Inject a crash after external success but before event commit and prove the retry does not repeat the effect.
F-003	critical	partially_mitigated	Deployment model conflicts with globally shared mutable data	Impact: One user can be affected by another user's global configuration or data; future multi-user deployment risks cross-tenant leakage and confused authority. Correction: Choose and enforce either explicit single-owner mode or workspace/tenant ownership across every mutable record and query. Acceptance: Create two tenants and prove every read, write, audit, template, skill, run, and artifact is isolated under adversarial identifiers.
F-004	critical	fixed_in_v8	HTTP and provider endpoints allowed server-side request forgery	Impact: An agent could probe internal services, cloud metadata, or local control planes. Correction: Keep destination and redirect validation, DNS resolution checks, and explicit local-model exceptions under policy. Acceptance: Run the egress suite against loopback, RFC1918, link-local, metadata, IPv6, encoded addresses, mixed DNS answers, and redirect chains.

ID	Severity	Status	Title	Impact / correction / acceptance
F-005	critical	fixed_in_v8	Invalid or cyclic plans could be reported as completed	Impact: A structurally impossible plan could produce a false success signal and misleading evidence. Correction: Retain preflight plan validation and fail closed when unfinished work has no executable node. Acceptance: Test duplicate nodes, unknown edges, self-dependencies, cycles, excessive steps, and runtime deadlock.
F-006	critical	fixed_in_v10	No tested sovereign backup and restore path	Impact: Loss or corruption of the SQLite database, keys, artifacts, or model configuration can be unrecoverable. Correction: Run periodic clean-deployment RTO/RPO drills and store the passphrase separately from the backup. Acceptance: Restore the encrypted backup into a clean target, verify the sentinel data and database checks, then prove wrong-key, tamper, and unauthorized-overwrite attempts fail closed.
F-007	high	open	Drizzle ORM remains on a version with a high-severity advisory	Impact: Unsafe identifier construction in affected paths can turn application input into SQL structure rather than data. Correction: Upgrade Drizzle ORM to a supported non-vulnerable release, regenerate/migrate safely, and execute database integration tests. Acceptance: npm audit contains no high advisory for Drizzle and all migration/query/integration tests pass on a clean install.
F-008	high	fixed_in_v8	Any authenticated user could mutate global policy	Impact: A normal user could weaken approval requirements for all users. Correction: Retain explicit administrative authorization and later tenant-scope policy records. Acceptance: A non-admin receives a denial and cannot change persisted policy; an authorized admin creates an attributable audit event.
F-009	high	fixed_in_v8	Skill identifiers enabled cross-user prompt access or attachment	Impact: A user who guessed an identifier could read or attach another user's procedural prompt material. Correction: Keep owner/built-in checks on both reads and relationship writes. Acceptance: Attempt direct reads and attachment with another user's skill identifier and prove denial without existence leakage.

ID	Severity	Status	Title	Impact / correction / acceptance
F-010	high	fixed_in_v8	New or empty agents inherited every tool	Impact: A minimally configured agent could unexpectedly gain network or write authority. Correction: Keep an explicit low-risk default allowlist and treat an empty list as no capabilities. Acceptance: Create agents with omitted and empty tool lists; prove only documented tools can execute.
F-011	high	fixed_in_v8	Catch-all policy allowed medium-risk actions automatically	Impact: Risky actions could bypass human review despite the UI implying otherwise. Correction: Keep fail-closed fallback policy and require explicit, narrow auto-approval rules. Acceptance: Unknown and medium/high-risk actions resolve to human review or denial in policy tests.
F-012	high	partially_mitigated	Runs and approvals have no complete wall-clock deadline model	Impact: A run can occupy resources indefinitely or remain pending forever after user abandonment. Correction: Add persisted deadlines, timeout ownership, cancellation propagation, and deterministic terminal states. Acceptance: Advance a fake clock across model, tool, approval, and run deadlines and prove exact terminal events and released leases.
F-013	high	partially_mitigated	Run event sequence allocation is race-prone	Impact: Concurrent writers can duplicate or reorder sequence numbers and break replay evidence. Correction: Use a transactionally allocated sequence or append-only event table with a unique run/sequence constraint and retry. Acceptance: Run concurrent appenders and prove contiguous unique ordering under load and injected transaction retries.
F-014	high	partially_mitigated	Audit hash-chain append is race-prone and not externally anchored	Impact: Concurrent events can fork the chain; a database administrator can rewrite the entire chain and recompute hashes. Correction: Serialize append, add uniqueness, sign periodic roots, and optionally export roots to independent storage. Acceptance: Generate concurrent audit writes, verify one linear chain, then mutate history and prove signed-root verification fails.

ID	Severity	Status	Title	Impact / correction / acceptance
F-015	high	fixed_in_v8	Disabled provider configurations were still eligible	Impact: An operator could believe a provider was disabled while the system still sent data to it. Correction: Retain enabled checks at every provider resolution boundary. Acceptance: Disable each provider and prove dispatch, health test, and fallback routing never contact it.
F-016	high	fixed_in_v8	Database migration failure was tolerated	Impact: The application could write incompatible data or fail later in less diagnosable ways. Correction: Keep startup fail-closed for required schema migrations. Acceptance: Force a migration failure and prove the process refuses readiness without serving mutation routes.
F-017	high	partially_mitigated	Fetched content remains a prompt-injection channel	Impact: A malicious page can attempt to override instructions, induce tool use, or exfiltrate context. Correction: Separate data from instructions, apply trust labels in the internal protocol, and require policy authorization independent of model text. Acceptance: Use adversarial fetched pages that request secrets and destructive tools; prove zero authority escalation and no protected-context leakage.
F-018	high	environment_blocked	Native database integration tests cannot run in the constrained environment	Impact: Critical approval expiry, audit, and runner integration behavior is not independently executed in this environment. Correction: Run the blocked suites on an approved clean Linux CI image with pinned Node headers and a trusted prebuilt/native toolchain. Acceptance: All database suites pass from a clean lockfile install and publish logs, environment digest, and database reset evidence.
F-019	high	environment_blocked	Production build did not complete end-to-end in the audit environment	Impact: A source-level and compile-level green result does not prove deployable application startup or route data collection. Correction: Run the build with the verified native binding on a trusted CI or development host, then execute startup and browser E2E gates. Acceptance: A clean install completes the production build, starts the server, and passes Playwright without hidden network or native-binding errors.

ID	Severity	Status	Title	Impact / correction / acceptance
F-020	high	partially_mitigated	User data export, correction, and deletion are not implemented end-to-end	Impact: Users cannot exercise data rights reliably and deleted data may survive in logs, artifacts, or backups. Correction: Implement data inventory-backed export and deletion workflows with tombstone/backup semantics and audit evidence. Acceptance: Create a user with all data classes, export it, delete it, search every primary/derived store, restore an older backup, and prove policy-compliant handling.
F-021	high	fixed_in_v10	Custom templates are globally visible and mutable	Impact: Private workflows or proprietary prompts can be exposed or changed across users. Correction: Separate immutable built-ins from tenant-owned custom templates and scope every query. Acceptance: Two-user route tests prove private templates cannot be listed, read, updated, or referenced cross-tenant.
F-022	high	partially_mitigated	Audit access is restricted but audit data remains globally modeled	Impact: A global administrator becomes a high-value data aggregation point and tenant-level audit cannot be safely delegated. Correction: Add tenant/workspace dimensions and explicit audit-reader roles while preserving system-level security audit separation. Acceptance: Tenant auditors see only their workspace; system auditors see redacted cross-tenant metadata under separate authorization.
F-023	high	fixed_in_v10	Registration remains open with weak abuse controls	Impact: An exposed installation can be populated by unauthorized users and amplified against local or paid model resources. Correction: Add explicit registration mode, invitation/first-owner bootstrap, stronger password checks, throttling, and non-enumerating responses. Acceptance: Unauthenticated registration is denied in closed mode; invite reuse, enumeration, weak passwords, and burst attempts fail safely.

ID	Severity	Status	Title	Impact / correction / acceptance
F-024	high	partially_mitigated	Secret encryption lacks documented rotation and context binding	Impact: A leaked master key or ciphertext relocation can expose all provider credentials with limited recovery options. Correction: Introduce key IDs, rotation, AEAD associated data, scoped decrypt authority, secure backup handling, and revocation drills. Acceptance: Rotate from key A to B without downtime, prove old ciphertext migration, reject swapped record context, and restore credentials securely.
F-025	high	partially_mitigated	Run creation has no client idempotency contract	Impact: Network retries or double clicks can duplicate expensive or destructive work. Correction: Accept scoped idempotency keys, persist request/result hashes, and return the original run for safe retries. Acceptance: Send the same request concurrently and repeatedly; prove exactly one run and a deterministic replay response.
F-026	high	partially_mitigated	Approval expiry is not owned by a durable timer	Impact: Expired approvals can remain pending or resume ambiguously, blocking work and weakening policy guarantees. Correction: Persist approval deadlines and let a durable worker own expiry, cancellation, and notification. Acceptance: Restart before and after expiry and prove one deterministic expired transition and no later execution.
F-027	high	partially_mitigated	Restart semantics for pending approvals are incomplete	Impact: An approved action may never resume or may be reissued incorrectly after restart. Correction: Persist the wait contract, durable timer, continuation pointer, and requeue behavior in the active runner. Acceptance: Restart with a pending approval, decide it from another process, and prove the exact continuation resumes once.
F-028	high	fixed_in_v8	Configured maximum plan size was not enforced	Impact: A model could create runaway work graphs and consume disproportionate resources. Correction: Keep max-step enforcement at parse/validation time. Acceptance: Generate plans at limit, limit+1, and extreme sizes; prove bounded parse time and clear rejection.
F-029	high	fixed_in_v8	Tool iteration exhaustion could be treated as success	Impact: Incomplete or looping work could be presented as successful. Correction: Fail the step and run with explicit budget-exhausted evidence. Acceptance: Use a model fixture that always requests another tool and prove deterministic failure at the configured limit.

ID	Severity	Status	Title	Impact / correction / acceptance
F-030	medium	fixed_in_v8	Usage accounting could double-count tokens	Impact: Cost, capacity, and model-routing decisions could be based on inflated telemetry. Correction: Use one authoritative accounting path with reconciliation fields. Acceptance: Replay a response with provider usage events and summary usage; prove totals equal the provider bill once.
F-031	medium	fixed_in_v8	Rejected approval did not close the tool evidence chain	Impact: Evidence reconstruction reported an unmatched call and could not explain the human decision path. Correction: Emit a terminal tool result representing rejection without executing the tool. Acceptance: Reject an approval and prove call/result pairing, no side effect, and visible human-decision evidence.
F-032	medium	partially_mitigated	Prompts and objectives are duplicated into persistent evidence without minimization	Impact: Sensitive business data can persist longer and in more stores than users expect. Correction: Store references/hashes and redacted summaries by default; define an explicit secure evidence retention mode for full content. Acceptance: Insert known sensitive markers and prove default logs/events/audit omit them while authorized artifact storage remains traceable.
F-033	medium	fixed_in_v8	Artifact writes had no practical size ceiling	Impact: A model could exhaust memory, disk, database capacity, or UI rendering. Correction: Keep a documented byte cap and later add streaming/object storage where justified. Acceptance: Attempt boundary, boundary+1, and multibyte payloads and prove exact size enforcement.
F-034	medium	fixed_in_v10	Policy regular expressions can create denial of service	Impact: Catastrophic backtracking can block the Node.js event loop during authorization. Correction: Use constrained glob/pattern semantics or safe-regex validation and bounded evaluation. Acceptance: Submit known pathological expressions and long inputs; prove bounded latency or rejection.

ID	Severity	Status	Title	Impact / correction / acceptance
F-035	medium	partially_mitigated	Rate limiting is process-local and trusts client forwarding headers	Impact: Attackers can bypass limits across workers/restarts or by rotating forged header values. Correction: Use authenticated principal/workspace keys and a shared limiter or documented single-process boundary; configure trusted proxies explicitly. Acceptance: Exercise multiple workers, restarts, spoofed headers, users, and IPs; prove the intended global and per-user budget.
F-036	medium	partially_mitigated	Security headers improved but CSP remains absent	Impact: A future injection bug has fewer browser-side containment barriers. Correction: Add nonce/hash-based CSP, report-only rollout, and route tests without breaking Next.js runtime behavior. Acceptance: Production responses include the approved CSP and Playwright confirms no required script/style violations.
F-037	medium	partially_mitigated	Source lint is intentionally shallow and build ignores ESLint	Impact: Common correctness, React, security, and accessibility defects can pass CI. Correction: Adopt a pinned non-interactive ESLint configuration plus targeted security/accessibility rules and keep the fast scanner as an additional gate. Acceptance: A clean install runs lint non-interactively; seeded violations fail with stable diagnostics.
F-038	high	fixed_in_v10	No generated SBOM, model inventory, or build provenance	Impact: Operators cannot reliably identify vulnerable components, licenses, models, plugins, or reproduce the artifact. Correction: Generate CycloneDX/SPDX, license inventory, model/plugin hashes, and build provenance during release. Acceptance: The extracted ZIP contains validated inventories matching the lockfile and shipped artifacts, signed or hashed in the release manifest.
F-039	high	partially_mitigated	Observability lacks traces, SLOs, and capacity evidence	Impact: Operators cannot answer why work is slow, expensive, failing, or saturating resources. Correction: Add redacted trace correlation, metrics, usage reconciliation, queue measures, SLOs, and local dashboards. Acceptance: A benchmark run yields traceable p50/p95/p99 latency, queue depth, failure classes, token/cost totals, and an SLO verdict.

ID	Severity	Status	Title	Impact / correction / acceptance
F-040	high	fixed_in_v11	Governed memory architecture is documentation-only	Impact: Long-running agents either forget important context or accumulate untrusted, stale, contradictory, or cross-user material. Correction: Maintain ablation and poisoning evaluations before expanding automatic memory creation. Acceptance: Create contradictory, expired, private, corrected, and deleted memories; prove scoring, provenance, isolation, and removal behavior.
F-041	high	fixed_in_v11	Provider selection is not a measured capability router	Impact: Critical work can be dispatched by static configuration rather than demonstrated fitness. Correction: Populate profiles through repeatable benchmark runs and invalidate stale evaluations. Acceptance: Given constrained tasks and unavailable models, route to the Pareto-eligible candidate or return no-eligible-model without silent downgrade.
F-042	high	partially_mitigated	Test portfolio is too narrow for the threat and failure model	Impact: The system can pass 47 safe tests while remaining unsafe under realistic operation. Correction: Build layered adversarial and fault-injection suites tied to every high/critical finding. Acceptance: Each high/critical finding has a failing regression before repair and a passing independent verification after repair.
F-043	medium	partially_mitigated	End-to-end tests are brittle smoke checks	Impact: The suite is materially less brittle, but shared-state and unexecuted browser coverage can still conceal authorization, recovery, accessibility, or concurrency regressions. Correction: Add per-run isolated databases and users, deterministic fixture teardown, accessibility checks, authorization negatives, restart recovery, and repeated serial/parallel flake measurement. Acceptance: Run the E2E suite repeatedly in serial and parallel modes against isolated state, including accessibility, authorization, offline, and recovery cases, with a bounded measured flake rate.

ID	Severity	Status	Title	Impact / correction / acceptance
F-044	medium	fixed_in_v10	Seed workflow is destructive and includes known demo credentials	Impact: Running it in the wrong environment can destroy data or create an easily guessed account. Correction: Require explicit development/test environment, random ephemeral credentials, targeted fixture cleanup, and destructive confirmation guards. Acceptance: Attempt seed in production mode and against a non-empty protected database; prove hard refusal and no mutation.
F-045	medium	partially_mitigated	Evidence percentage measures structure, not truth	Impact: Users can over-trust a complete-looking ledger even when outputs are wrong or self-verified. Correction: Keep structural labeling and add claim-level evidence, verifier identity, reproducibility, contradiction, and semantic evaluation. Acceptance: Show a structurally complete but deliberately false run and prove the UI does not label it verified.
F-046	high	partially_mitigated	Most canonical capabilities remain blocked or unimplemented	Impact: Documentation volume can be mistaken for platform maturity, obscuring the implementation gap. Correction: Expose implemented-versus-designed status prominently and execute dependency-unblocking vertical slices rather than adding parallel documents. Acceptance: A release dashboard derives status from code/test evidence and cannot count designed-only tasks as delivered capability.
F-047	high	partially_mitigated	SQLite and web-process topology limit safe scale and failover	Impact: Multi-process deployment, failover, concurrent writers, and horizontal scaling can corrupt assumptions or lose work. Correction: Define supported single-node limits, separate durable worker execution, and introduce a tested persistence profile before scaling out. Acceptance: Run load and failover tests at documented limits; unsupported topologies must fail configuration validation.
F-048	high	partially_mitigated	No tested Content Security Policy	Impact: Cross-site scripting impact is not meaningfully contained at the browser policy layer. Correction: Design and roll out report-only then enforced CSP with route-level automated checks. Acceptance: All production pages load under enforced CSP with no unauthorized script, style, frame, connect, image, or font source.

ID	Severity	Status	Title	Impact / correction / acceptance
F-049	high	fixed_in_v11	Tool arguments are not uniformly governed by explicit versioned schemas	Impact: Malformed, oversized, ambiguous, or injected arguments can reach tool implementations inconsistently. Correction: Add OS-level isolation for high-risk tools and maintain mutation tests for schema bypass. Acceptance: Fuzz every tool with invalid types, extra fields, oversized values, Unicode edge cases, and schema-version mismatch.
F-050	high	partially_mitigated	Context and output budgets are incomplete	Impact: Long histories or retrieved content can crowd out policy/current facts, increase cost, and degrade correctness. Correction: Implement mandatory-context reservation, measured selection, output ceilings, and bounded planner/critic/verifier stopping. Acceptance: Run adversarial long-context cases and prove mandatory policy/current code facts survive while cost and latency remain within budget.
F-051	critical	fixed_in_v12	Stale workers could commit after lease takeover when identity was reused	Impact: Split-brain workers could overwrite checkpoints or complete a job after losing authority, invalidating exactly-once and recovery claims. Correction: Require a fencing token on every lease-bound mutation and reject stale tokens in memory and SQLite adapters. Acceptance: Acquire a lease twice with the same worker identity after expiry; token 1 must be rejected and token 2 must commit.
F-052	high	fixed_in_v12	Approval resolution lacked a cross-process compare-and-set revision	Impact: A stale operator action or concurrent process could overwrite or contradict the authoritative human decision. Correction: Persist an approval revision and update terminal status only when id, prior status, and revision all match. Return a conflict to stale clients. Acceptance: Two resolutions using the same expected revision must yield one successful transition and one approval_revision_conflict.
F-053	high	fixed_in_v12	Verification decisions were not immutably bound to tested source and release artifacts	Impact: A verification label could outlive or refer to different code and test evidence, creating false release confidence. Correction: Create hash-bound verification attestations, reject builder/verifier identity collisions, and expose absent verification in the interface. Acceptance: Changing any bound field must invalidate the evidence hash; self-verification must be rejected.

ID	Severity	Status	Title	Impact / correction / acceptance
F-054	high	fixed_in_v12	Runtime calm could be mistaken for release or pilot readiness	Impact: An operator could interpret zero failures in an empty or lightly used system as evidence that the release was pilot-ready. Correction: Add a conservative evidence gate that treats unknown release evidence as blocking and separates runtime health from release classification. Acceptance: Healthy empty metrics with unknown release facts must remain DEVELOPMENT ONLY; controlled pilot requires every hard fact.
F-055	high	fixed_in_v12	Model routing did not distinguish verification quality or unhealthy candidates	Impact: Verification tasks could select a strong builder but weak reviewer, or choose an unavailable model if other metrics were attractive. Correction: Record verification quality and health, apply task-class weighting, and reject unavailable candidates as a hard constraint. Acceptance: A verification task must select the eligible high-verification model and reject an unavailable higher-scoring model.
F-056	critical	partially_mitigated	Active approval waits were process-local and could not resume after restart	Impact: A restart during a risky action could leave the run permanently waiting or tempt an operator to repeat a side effect. Correction: Execute native restart integration in the isolated lane and prove the exact approved step resumes once after process replacement. Acceptance: Persist a pending approval, terminate the process, restart, resolve the expected revision, and prove one side effect and one terminal durable state.
F-057	critical	partially_mitigated	Pilot resources lacked a complete tenant and workspace boundary	Impact: Resource identifiers could cross user or workspace boundaries even when individual routes appeared owner-filtered. Correction: Run native cross-tenant API, search, artifact, approval, verification, export, backup, and restore tests, including mutations that remove predicates. Acceptance: Every cross-tenant read and write must fail, and removing one tenant predicate must make the suite fail.
F-058	high	fixed_in_v13	Pilot readiness could be implied by static or missing evidence	Impact: Operators could interpret an incomplete checklist or completed run as proof that the release was safe for pilot use. Correction: Keep fail-closed evidence semantics and regression tests for every unknown gate. Acceptance: Removing any mandatory evidence item must change the run to blocked and identify the missing evidence.

ID	Severity	Status	Title	Impact / correction / acceptance
F-059	high	fixed_in_v13	Database initialization during module import broke production build discovery	Impact: A clean source build required a native runtime binding even when no database query was executed, preventing reproducible packaging and hiding build/runtime boundaries. Correction: Retain lazy initialization and verify the complete build in both source-safe and native CI lanes. Acceptance: Import the database module without a native binding and complete `next build` without opening SQLite.
F-060	high	partially_mitigated	Native persistence validation is unavailable on the protected host	Impact: SQLite transactions, multi-process races, migrations, durable approval restart, and production runtime behavior are not locally proven. Correction: Run the pinned isolated validation workflow and attach dependency provenance, native results, migrations, build, and resource metrics. Acceptance: The isolated lane must install from lockfile, run all native suites, and publish machine-readable evidence with exact package and binary provenance.
F-061	high	environment_blocked	Browser, accessibility, and visual regression gates are not executed locally	Impact: Keyboard, focus, responsive, accessibility, restart, reconciliation, and operator-truth behavior are not browser-verified. Correction: Execute Chromium, Firefox, mobile, accessibility, and visual regression in the pinned disposable CI lane. Acceptance: All pilot browser scenarios must pass with screenshots, traces, accessibility results, and responsive evidence.
F-062	critical	open	Final verification is not yet independently bound to the released ZIP hash	Impact: The builder could package source that differs from tested evidence or overstate readiness. Correction: Freeze the release, execute all isolated gates, bind evidence to the archive hash, and run a distinct verifier invocation that attempts rejection. Acceptance: A distinct verifier identity must accept the exact final ZIP SHA-256 with all required evidence hashes and no hidden critical limitation.

ID	Severity	Status	Title	Impact / correction / acceptance
F-063	critical	accepted_risk	Live remote model conversations remain outside restart-safe pilot execution	Impact: A restart during a live remote model interaction can require re-execution, consume additional cost, or produce a non-equivalent response. Correction: Deny live-provider pilot execution until model request intents, response references, replay policy, cost accounting, and privacy scope are durable. Acceptance: Terminate before and after a remote response and prove deterministic continuation or explicit reconciliation without silent re-request.
F-064	critical	fixed_in_v14	Runtime migration discovery applied only the first declared schema change	Impact: Production startup could omit durable, memory, tenancy, verification, and approval columns, creating runtime failures and misleading release evidence. Correction: Keep ordered SQL files canonical, persist each filename and SHA-256, and reject migration drift. Acceptance: Apply all migrations to a clean database, rerun idempotently, and fail after modifying a historical migration.
F-065	high	fixed_in_v14	Static generation inherited an unbounded host CPU count	Impact: Builds could stall, exhaust memory, or interfere with other workloads on high-core-count hosts. Correction: Keep explicit bounded build concurrency and record build duration and route metrics. Acceptance: Complete the production build with two workers and a successful exit.
F-066	high	fixed_in_v14	Demo seed referenced tenant and workspace identifiers without creating the scope rows	Impact: Demo and E2E state could appear scoped while lacking the membership records used by backend authorization. Correction: Create the personal pilot scope before seeding scoped agents or runs. Acceptance: Seed a clean database and verify tenant, workspace, membership, run, approval, and artifact scope survive backup and restore.
F-067	high	environment_blocked	The local browser executable is governed by a deny-all URL policy	Impact: Browser E2E, keyboard, responsive, offline, accessibility, and visual-regression claims cannot be made from this host. Correction: Execute the pinned browser lane in a disposable CI worker and retain the local block as a release blocker. Acceptance: The same frozen candidate passes Chromium browser, accessibility, offline, and responsive tests in the disposable lane.

ID	Severity	Status	Title	Impact / correction / acceptance
F-068	high	fixed_in_v14	Restore interruption after target displacement lacked a rollback proof	Impact: An interrupted restore could have been claimed atomic without evidence at the most dangerous boundary. Correction: Retain explicit fault injection and regression coverage around target displacement. Acceptance: Inject failure immediately after displacement and verify the original target bytes remain available.
F-069	high	open	Full-process outbound network behavior is not independently audited	Impact: An undeclared dependency or library call could escape the application-level guard and invalidate air-gap claims. Correction: Run the extracted release in an isolated network namespace with deny-by-default egress and capture all connection attempts. Acceptance: Complete startup and the zero-key workflow with egress denied, zero unexpected attempts, and machine-readable capture bound to the release hash.
F-070	critical	open	No real local generative model artifact has been benchmarked	Impact: Model sovereignty, task quality, tool reliability, memory behavior, latency, and hardware feasibility remain unproven for a useful generative workload. Correction: Benchmark at least one license-reviewed local model artifact in a disposable environment and bind its hash, runtime, quality, memory, latency, and energy evidence to the registry. Acceptance: A real local model completes the sovereign golden workflow and adversarial structured-output tasks without commercial keys.
F-071	high	open	Energy-aware scheduling uses estimates rather than measured hardware data	Impact: Energy-saving, thermal-protection, and local-versus-remote break-even decisions may be materially wrong on target hardware. Correction: Collect repeated wall-power or trusted telemetry measurements for idle, model load, inference, retrieval, backup, and restore. Acceptance: Measured profiles include confidence intervals and alter routing only within validated bounds.

ID	Severity	Status	Title	Impact / correction / acceptance
F-072	high	open	Clean offline installation still depends on an unbuilt dependency bundle	Impact: Loss of public registries or model hubs prevents clean installation and disaster recovery onto replacement hardware. Correction: Create a license-compliant signed installation bundle with package, system, browser, and model manifests plus integrity verification. Acceptance: Install and validate the extracted release on a clean disconnected machine with public registries unavailable.
F-073	high	fixed_in_v15	Signed air-gap bundles were replayable and ignored local key revocation	Impact: An attacker or operator error could repeat bounded work, duplicate local writes, or accept evidence from a revoked offline node. Correction: Retain purpose-scoped trust checks and a durable replay ledger at the acceptance boundary. Acceptance: A new process instance rejects a consumed bundle, and a revoked key is rejected before payload acceptance.
F-074	high	partially_mitigated	Offline update migration execution is declared but not automatically rehearsed	Impact: A source update may apply successfully while its schema change fails or cannot be rolled back. Correction: Add a staged database-copy rehearsal, migration ledger verification, application validation, and explicit schema rollback policy before committing the update. Acceptance: An update with a real migration passes dry run, apply, validation, rollback, and previous-version revalidation offline.
F-075	medium	partially_mitigated	Root and signing keys lack protected hardware custody and rotation proof	Impact: Host compromise could expose all software-protected sovereign identities and backup keys. Correction: Implement optional OS keychain or TPM-backed adapters, rotation ceremonies, recovery-key separation, and secret-access audit. Acceptance: Rotate installation, tenant, backup, and signing keys without losing authorized data; revoked versions cannot sign or decrypt new material.
F-076	medium	partially_mitigated	Monolithic test orchestration retains an open handle after all suites report	Impact: CI can hang after successful tests, wasting capacity and obscuring real timeouts. Correction: Identify the leaked timer, database handle, worker, or server and add an open-handle regression gate. Acceptance: The single monolithic test command exits zero within its bounded budget after running the same 180 tests.

Appendix B - Evidence hashes

Evidence object	SHA-256
verticalSlices	18295152d9af3ab27e5fd32df1a6692149fdec4114f2ce5a00ce22ac1f643056
dependencyLedger	f528c384475faa0685810bf5a7f59aea2f960b6f21984961328845973f34464e
networkEvidence	65a08a2991b7667d6674a368c5d3e46b9e2e3c9760efb3b652d863a1e54d13e3
modelRegistry	4bb90bfe353565673408331ae90bdab7108fe5a464c082f9f61b356c6e927dd4
hardwareEnergy	82010d88d50ef9eb7d7532fcab67e353994be6e8b71b24f29c408a8fc66bc6d1
controlPlane	d71227d409437ee89a83312c5049e3c1cd06b5b34691c2df1c1d37c3dce53880
signedAirGapHandoff	f433c75e25da663f476d1e5ed7212e55379898e9b7497b2c86afc95b175049d5
signedOfflineUpdate	f6d1fb8ef4c3064f65a43d605835e0a7984fb0627249416b75706eda176ade5a
sovereigntyLedger	5c64594088bfbd317384223f82182da02c45a1161f592bc4f6a18a1b53aa84b5

Appendix C - Final blockers

- hardware_energy_measurement_missing
- outbound_network_audit_incomplete
- real_local_model_quality_not_benchmarked
- offline_clean_installation_bundle_missing
- offline_update_database_migration_rehearsal_missing
- protected_hardware_key_custody_unproven